

Mass Owning of Seedboxes - A Live Hacking Exhibition.

“No one hacks at DEFCON any more.”
-anon

No one hacks at DEFCON any more.

What are seedboxes ? What's on them ? who/what/why -

Major providers:

seedhost.eu / seedboxes.eu / whatbox.ca / [rapidseedbox](https://rapidseedbox.com) / [dediseedbox](https://dediseedbox.com)

[Feralhosting](https://feralhosting.com) / [Andy10gbit](https://andy10gbit.com) / my-seedbox.com / giga-rapid.com / cloudboxes.io

Cost: 1 Euro to 50 Euro a month. (yes they take bitcoin, stop asking. No, they don't accept dogecoin. I don't think they accept NFT as trades.. Why are you asking me this crap? No I don't run a seedbox. Which one

is best? I don't know, leave me alone. For the last time, I'm not telling you my real name. don't let this distract you from the fact that in 1998, the undertaker threw Mankind off Hell In A Cell, and plummeted 16 ft through an announcer's table.

Software run by “users”

Indexers (Jackett / Prowlarr)

NZBGet / SABNZB / Usenet Downloaders : Web interfaces with stored creds

Bittorrent software (rutorrent, rtorrent, Deluge, transmission, etc): Web interfaces

Sonarr / Radarr / Lidarr / Whisparr : Automatically downloads shows/movies using:

- 1) List of Indexers (What are indexers? public/private)
- 2) Download Agents (NZB or BitTorrent)

Ways to hack that same software

Indexers (Jackett / Prowlarr)

Some aren't password protected - and leak API keys and l/p to private sites

Why pay for "l33t" private sites when you can steal API keys for them instead?

NZBGet / SABNZB / Usenet Downloaders : Web interfaces with stored creds

They leak API keys and l/p to the usenet provider\$\$\$\$\$

Why pay for Usenet access when you can just steal it?)

Bittorrent software (rutorrent, rtorrent, deluge, transmission, etc):

If protected, most/some use same l/p as Linux system

Most have "file" level controls to open/rename/move/delete files on file system.

Ways to hack that same software (pt 2)

Sonarr / Radarr / Lidarr / Whisparr :

- They all leak logins/passwords to download agents (local torrent/nzb)
- They all leak API keys to Indexers and Downloader Agents
- They all have terrible security out of box
- They all leak file structure of local system
- They all only have one level of access - you can delete everything.
- Only some of the seedhost providers properly jail their *ARR software.

Some seedbox providers use the same passwords to access usenet/torrent/radarr/sonarr/FTP/SFTP and SSH. (Hint, SSH is the part that should make you go “ooooooooohhhh nooooooooo” or “oh hell yes!”).

Lets Hack - Recon

List of seed host IP addresses (whois/arin)

Search on censys.io / Shodan for “radarr” “sonarr” or search under seedbox providers domain names

Google Search

Inurl:sonarr -Login

Site:someseedhostprovider.eu “index of”

Site:someseedhostprovider.eu sonarr

Site:someseedhostprovider.eu radar

Lets Hack - Scan

Portscan all ports on all seedhost providers.

Seedhost providers use high ports (10000-50000) for servers

I use about 20-30 threads of port scanners at a time.

Lots of small ranges to avoid timeouts.

Why port scan ? You need up to the minute results (well, up to the week)

Do a GET / HTTP/1.0 on all open ports.

Do a HTTPS - GET / HTTP/1.0 on all open ports.

~90% of websites found are HTTP

Lets Hack - Analyze

Search results. I usually search for “/title” `fgrep -r /title`

```
./185.203.56.35:22068/index.html: <title>Login - Sonarr</title>
./212.7.202.7:16214/index.html: <title>Deluge WebUI 2.0.5</title>
./46.232.210.50:15241/index.html: <title>qBittorrent Web UI</title>
./95.211.156.138:10301/index.html: <title>Ombi</title>
./5.79.98.143:11723/index.html: <title>CouchPotato</title> *****
./5.79.98.200:11309/index.html: <title>Lidarr</title> *****
./5.79.98.155:10729/index.html: <title>Sonarr</title> *****
```


Live Demo

.....

Hacky hack hack hack

.....

In case I don't get to it during live talk ...

- Rclone.conf is a great target
- Vpn.conf / vpn.zip / username.ovpn - great way to get free VPN
- \$1 can get you a shell account on a small (insecure) VPS
- *arr does world-readable backups to /tmp/
 - sqlite3 *db "select * from downloadclients"
 - sqlite3 *db "select * from indexers"
 - Docker is bad (df/mount hack)
- Plaintext creds in nzbget.conf / sabnzb.ini / silc.conf / rclone.conf
- Giga-rapid.com sucks
- Seedhost.eu easiest target - biggest reward
- PLEX Tokens
- Orpheus - private torrent site - one admin uses a seedbox to leach/upload

Be careful...

Seedboxes protect you from your ISP - but that is all they do.

Your data is still at risk. Your data can/will be found.

If you pay for illegal things don't get mad when they are stolen.

Don't expect admins who run seedboxes to know anything about security.

Don't put API keys or passwords on seedboxes... you moron.

The FEDs could be doing these same attacks. I could see the real source IPs for all other users in `last` logs.

Lots of people used their same username on different providers.

Lots of people would tunnel data back to their home machine, or SSH to other boxes, like idiots.

bye

